

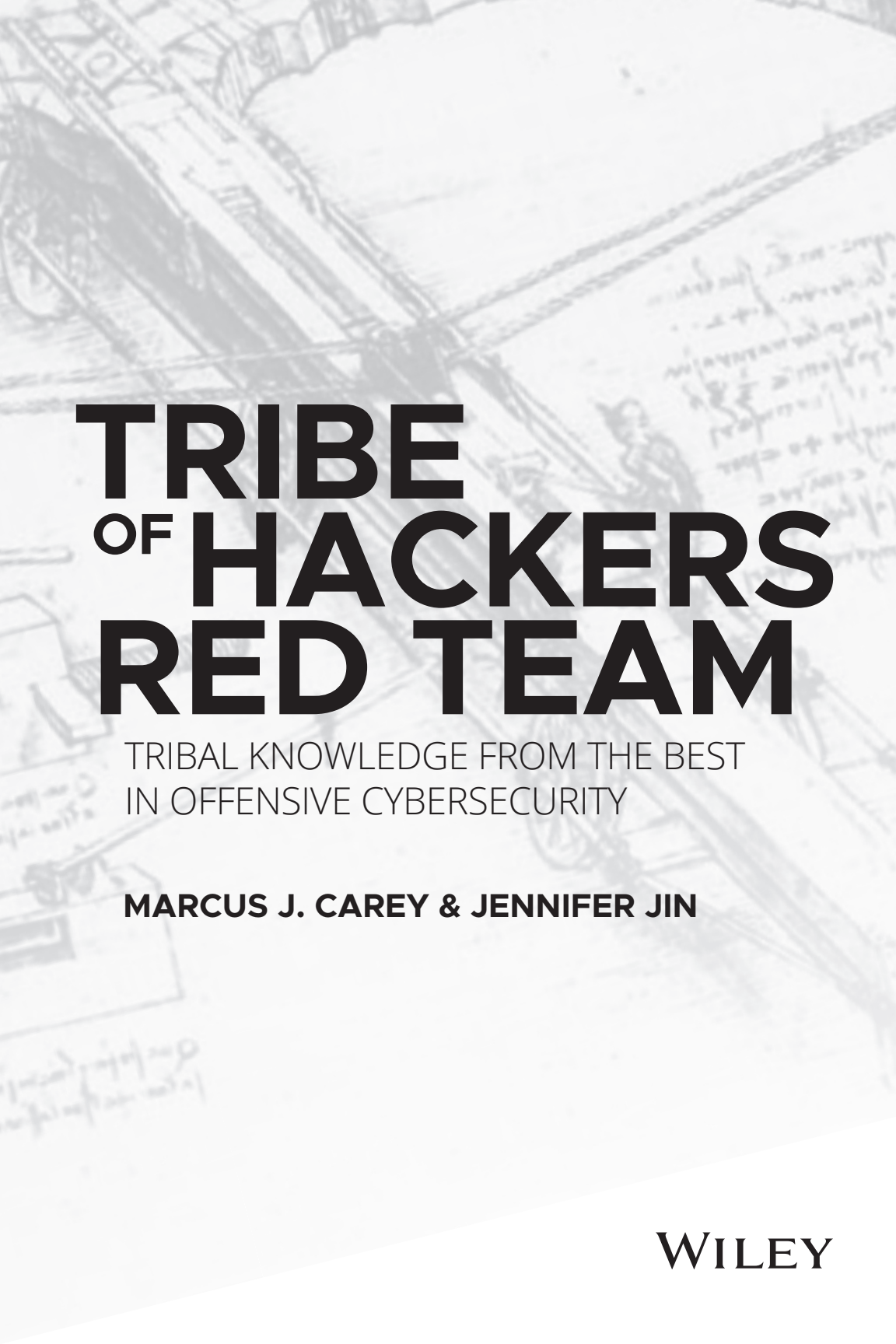
TRIBAL KNOWLEDGE FROM THE BEST
IN OFFENSIVE CYBERSECURITY

TRIBE OF HACKERS

RED TEAM

MARCUS J. CAREY
JENNIFER JIN

WILEY



TRIBE OF HACKERS RED TEAM

TRIBAL KNOWLEDGE FROM THE BEST
IN OFFENSIVE CYBERSECURITY

MARCUS J. CAREY & JENNIFER JIN

WILEY

Copyright © 2019 Marcus J. Carey and Jennifer Jin

Published by John Wiley & Sons, Inc. Indianapolis, Indiana

Published simultaneously in Canada

ISBN: 978-1-119-64332-6

ISBN: 978-1-119-64336-4 (ebk.)

ISBN: 978-1-119-64333-3 (ebk.)

Manufactured in the United States of America

No part of this publication may be reproduced, stored in a retrieval system or transmitted in any form or by any means, electronic, mechanical, photocopying, recording, scanning or otherwise, except as permitted under Sections 107 or 108 of the 1976 United States Copyright Act, without either the prior written permission of the Publisher, or authorization through payment of the appropriate per-copy fee to the Copyright Clearance Center, 222 Rosewood Drive, Danvers, MA 01923, (978) 750-8400, fax (978) 646-8600. Requests to the Publisher for permission should be addressed to the Permissions Department, John Wiley & Sons, Inc., 111 River Street, Hoboken, NJ 07030, (201) 748-6011, fax (201) 748-6008, or online at <http://www.wiley.com/go/permissions>.

Limit of Liability/Disclaimer of Warranty: The publisher and the author make no representations or warranties with respect to the accuracy or completeness of the contents of this work and specifically disclaim all warranties, including without limitation warranties of fitness for a particular purpose. No warranty may be created or extended by sales or promotional materials. The advice and strategies contained herein may not be suitable for every situation. This work is sold with the understanding that the publisher is not engaged in rendering legal, accounting, or other professional services. If professional assistance is required, the services of a competent professional person should be sought. Neither the publisher nor the author shall be liable for damages arising herefrom. The fact that an organization or Web site is referred to in this work as a citation and/or a potential source of further information does not mean that the author or the publisher endorses the information the organization or Web site may provide or recommendations it may make. Further, readers should be aware that Internet Web sites listed in this work may have changed or disappeared between when this work was written and when it is read.

For general information on our other products and services or to obtain technical support, please contact our Customer Care Department within the U.S. at (877) 762-2974, outside the U.S. at (317) 572-3993 or fax (317) 572-4002.

Wiley publishes in a variety of print and electronic formats and by print-on-demand. Some material included with standard print versions of this book may not be included in e-books or in print-on-demand. If this book refers to media such as a CD or DVD that is not included in the version you purchased, you may download this material at <http://booksupport.wiley.com>. For more information about Wiley products, visit www.wiley.com.

Library of Congress Control Number: 2019945380

TRADEMARKS: Wiley, the Wiley logo, and the Sybex logo are trademarks or registered trademarks of John Wiley & Sons, Inc. and/or its affiliates, in the United States and other countries, and may not be used without written permission. All other trademarks are the property of their respective owners. John Wiley & Sons, Inc. is not associated with any product or vendor mentioned in this book.

10 9 8 7 6 5 4 3 2 1



Contents

	Introduction	vi
01	Marcus J. Carey	1
02	David Bell	5
03	Paul Brager	10
04	Beau Bullock	16
05	Christopher Campbell	22
06	Stephanie Carruthers	28
07	Mark Clayton	34
08	Ben Donnelly	39
09	Skip Duckwall	47
10	Ronald Eddings	52
11	Justin Elze	57
12	Mike Felch	62
13	Kevin Figueroa	70
14	Marco Figueroa	75
15	Jared Folkins	80
16	Rob Fuller	86
17	Patrick Fussell	92
18	Chris Gates	97
19	Brian Genz	102
20	Jared Haight	112
21	Stephen Hilt	118
22	Brent Kennedy	122
23	David Kennedy	128
24	Maggie Ligon	139
25	Jeffrey Man	143
26	Tim MalcomVetter	151
27	Brandon McCrillis	161
28	Oddvar Moe	164
29	Chris Nickerson	169
30	Ryan O'Horo	176
31	Carlos Perez	179
32	Francesc Rodriguez	185
33	Derek Rook	190
34	Isaiah Sarju	195
35	Mary Sawyer	200
36	Bradley Schaufenbuel	204

37	Tinker Secor	210
38	Jayson E. Street	217
39	Chris Truncer	223
40	Carl Vincent	230
41	Georgia Weidman	238
42	Adam Willard	244
43	Jake Williams	248
44	Robert Willis	253
45	Robin Wood	259
46	Wirefall	264
47	Phillip Wylie	271
	Epilogue	274



Acknowledgments

Tribe of Hackers would not exist without the awesome cybersecurity community and the contributors in it. I owe them tremendously for allowing me to share their perspectives on our industry.

I'd like to give a special shout-out to my wife, Mandy, for allowing me to do whatever the heck I want as far as building a business and being crazy enough to do this stuff. To Erran, Kaley, Chris, Chaya, Justin, Annie, Davian, Kai: I love you all more than the whole world!

I also want to thank Jennifer Jin for helping build the Tribe of Hackers book series and summit. She would like to thank her parents for not thinking that she's crazy for quitting pre-med.

Thanks also goes to Jennifer Aldoretta for helping me build a company that is true to our values. Shout-out to every one of the people that I've worked with over the past few years.

Thanks to Dan Mandel, Jim Minatel, and the Wiley team for believing in the whole vision.

—Marcus J. Carey

Introduction

Howdy, my name is Marcus, and I'm a hacker. You probably picked up this book to learn from the best in red teams. I'm going to start off with one of my favorite sayings: "We have two ears and one mouth so that we can listen twice as much as we speak." This quote is attributed to the Greek Stoic philosopher Epictetus. Trying to live out that wisdom is something I may never master.

When I was young, I was a know-it-all. I'd argue just to be right even when confronted with facts that definitively showed I was wrong. I was that kid in class who would raise my hand at every question, practically jumping out of the seat when a question was asked.

At some point, my parents bought an encyclopedia set, which I read from cover to cover. I read dictionaries to learn new words. I wanted to be like Einstein and Martin Luther King, Jr., rolled up into one. This behavior of wanting to know everything and believing I was the smartest person on Earth was crushed when I joined the military.

I was pretty smart and an excellent test taker, so I got into the U.S. Navy's cryptologic program. After I left basic training and arrived at my technical training command, I noticed it was swamped with nothing but really smart people.

When I arrived in Scotland for my first duty station, it was more of the same. I worked with senior noncommissioned officers and civilians who absolutely blew my mind. The old me was still there, but I eventually put my pride away and started asking more questions. I started taking the saying "There is no such thing as a dumb question" seriously.

From then on, I asked the most questions. Asking questions, and more importantly, listening to what others had to say, changed my life and learning. I still read everything I could get my hands on and kept close to the people who knew their stuff.

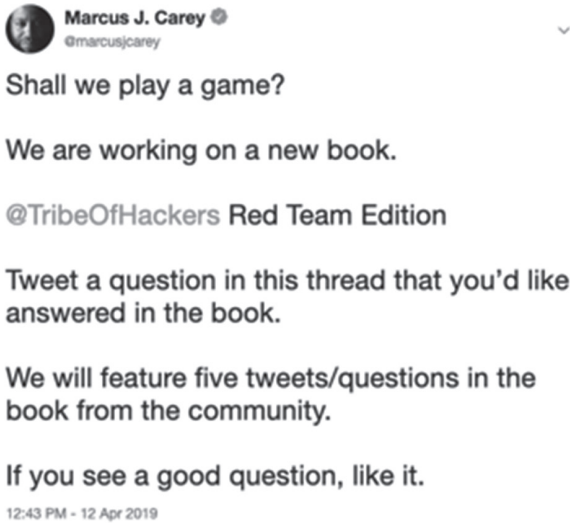
All my question-asking led me to a successful career in cybersecurity. My question-asking and listening was great when dealing with prospects and customers on the sales side of things. When people ask me how I got here, I tell them, "I ask more questions than anyone else."

Last year, when I started working on the original *Tribe of Hackers*, we asked more than 70 individuals in cybersecurity questions about how they started and found success. In this book, I've brought along a merry bunch of hacker friends who specialize in offensive security (aka red teaming).

Before we get started, let me quickly lay out what a red team is. A *red team* is a cybersecurity function that tests networks, applications, and systems to find vulnerabilities that may lead to compromise. Sometimes, red teams are allowed to exploit systems to validate that the vulnerability is real. Red teams also can perform physical assessments and social engineering engagements.

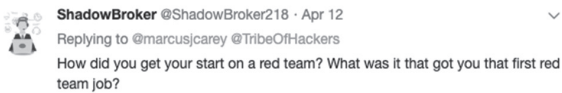
On the opposite side of the house, a *blue team* is responsible for monitoring networks, systems, and applications for intrusions and for making sure that the confidentiality, integrity, and availability of all assets are not affected. Nowadays, organizations are combining red and blue teams and sometimes use the term *purple team*.

To formulate questions, I reached out the cybersecurity community on Twitter to hear what they wanted to know about the most.



Originally, I planned on using five questions from the book, but on second thought, I decided to take more than five questions from the community. The following are the questions inspired by the response from the community, plus a few more from me.

1. How did you get your start on a red team?



2. What is the best way to get a red team job?
3. How can someone gain red team skills without getting in trouble with the law?
4. Why can't we agree on what a red team is?



5. What is one thing the rest of information security doesn't understand about being on a red team? What is the most toxic falsehood you have heard related to red, blue, or purple teams?



Eazy-EIP @n1c_fury · Apr 12
Replying to @marcusjcarey @TribeOfHackers
What is one thing the rest of infosec doesn't understand about being on a Red Team?



BuddhaOnSecurity @BuddhaOnSec · Apr 12
Replying to @marcusjcarey @lan_infosec @TribeOfHackers
What do you think is the single most toxic falsehood you have heard around red (and/or purple/blue) teams?

6. When should you introduce a formal red team into an organization's security program?



Accidental CISO
@AccidentalCISO

Follow

Replying to @marcusjcarey @TribeOfHackers

What is the appropriate point in the maturation of a security program to introduce a formal read team into the org?

9:37 AM - 13 Apr 2019



Isalah Sarju @Isalahsarju · Apr 12
Replying to @marcusjcarey @TribeOfHackers
How do you know when you can use a red team?

7. How do you explain the value of red teaming to a reluctant or nontechnical client or organization?

8. What is the least bang-for-your-buck security control that you see implemented?



Integgro
@Integgro

Follow

Replying to @marcusjcarey @TribeOfHackers

What is the least bang for your buck control you see implemented?

2:04 PM - 13 Apr 2019

9. Have you ever recommended not doing a red team engagement?



cyberphilosopher 

@_4_d_4_m_

Follow

Replying to @marcusjcarey @TribeOfHackers

At what point do you recommend not doing a red team, and offer something else more suitable, even when a customer asks for one?

2:16 PM - 12 Apr 2019

10. What's the most important or easiest-to-implement control that can prevent you from compromising a system or network?



spencer alessi @techspence · Apr 12

Replying to @marcusjcarey @TribeOfHackers

What's the most important and easiest to implement controls that would have prevented you from compromising a system/network? Eg how do we help smb defend better with less budget and less staff

11. Why do you feel it is critical to stay within the rules of engagement?



Shawn Romines

@infosecusa

Following

Replying to @marcusjcarey @TribeOfHackers

Why do you feel it is critical to stay within the rules of engagement?

3:54 PM - 12 Apr 2019

12. If you were ever busted on a penetration test or other engagement, how did you handle it?



Dean Tichenor @Viss · Apr 12

Replying to @marcusjcarey @TribeOfHackers

May I suggest a few of the phobos redteam interview questions?

- tell me story about being on a physical and getting caught
- walk me through how your malware got burned and you lost all your shells
- what was your craziest exfil
- what was your craziest 'busted' moment

13. What is the biggest ethical quandary you experienced while on an assigned objective?



ryan @skykn0t · Apr 12

Replying to @marcusjcarey @TribeOfHackers

What was the biggest ethical quandary you experienced while accomplishing your assigned objective?

14. How does the red team work together to get the job done?



LOKK1 @L0kk12 · Apr 12

Replying to @marcusjcarey @TribeOfHackers

Describe the team aspect of red team? How do you work together to get a job done? Including working with the blue team after? Or just some simple documentation tips?

15. What is your approach to debriefing and supporting blue teams after an operation is completed?



SHADOWOPS | DATA PRIVACY AND SECURITY RESEARCH ... · Apr 12

Replying to @marcusjcarey @TribeOfHackers

Can you describe your approach to debriefing and supporting blue teams after an operation is completed, and why you feel this is important to all teams regardless of their role?

16. If you were to switch to the blue team, what would be your first step to better defend against attacks?



(((Ken N.))) @Sakuracon

@K3n_5s

Follow

Replying to @Viss @marcusjcarey @TribeOfHackers

"If you were to be switched to blue, what would be your first three steps to better defend against attacks, and if they aren't commonly done already, why do you suppose that's the case?"

1:22 PM - 12 Apr 2019

17. What is some practical advice on writing a good report?

18. How do you ensure your program results are valuable to people who need a full narrative and context?



Mark @markstjohn · Apr 12

Replying to @marcusjcarey @TribeOfHackers

How do you ensure your program results are valuable to people who need a full narrative and context instead of a showcase of their weaknesses vs. your skill set?

19. How do you recommend security improvements other than pointing out where it's insufficient?



Rabbit @ra6bit · Apr 12

Replying to @marcusjcarey @TribeOfHackers

What have you done to improve security other than point out where it is insufficient?

20. What nontechnical skills or attitudes do you look for when recruiting and interviewing red team members?



Eric Kates @positronek · Apr 12

Replying to @marcusjcarey @TribeOfHackers

What is one of the most beneficial non-technical skills used for red-teaming activity?

21. What differentiates good red teamers from the pack as far as approaching a problem differently?



Chris Campbell

@obscuresec

Following

Replying to @marcusjcarey @TribeOfHackers

How does a good red teamer approach a problem differently than other types of testers?

12:45 PM · 12 Apr 2019

So, those are the 21 questions we asked 47 experts, including myself. I thought I'd chime in with my opinions to set the stage before getting to the 46 others. Hope you enjoy!

Marcus J. Carey
April 12, 2019



“Today, open source tools dominate the red team space, making it possible for more people to get familiar and practice.”

Twitter: @marcusjcarey • **Website:** <https://www.linkedin.com/in/marcuscarey/>

Marcus J. Carey

Marcus J. Carey is a cybersecurity community advocate and startup founder with more than 25 years of protecting government and commercial sensitive data. He started his cybersecurity career in U.S. Navy cryptology with further service in the National Security Agency (NSA).

1

How did you get your start on a red team?

The funny thing about my red team journey is I wasn't technically a paid red teamer until I got fired from a job and had to make ends meet. I picked up work at an East Coast consultancy doing penetration testing and product development.

I was able to gain red team skills by working at the Defense Cyber Crime Center (DC3). There I did research, taught, and did course development. Amazingly, I had access to all the red team tools that you could imagine, plus every digital forensics tool on the planet. I also had the pleasure of working with a guy named Johnny Long who was quite the hacker and red teamer himself.

I'm extremely lucky to have been in those positions to prepare me for a red team role. Today, open source tools dominate the red team space, making it possible for more people to get familiar and practice.

They say luck is when preparation meets opportunity. It sucks that I was laid off, but it was a blessing to have red team skills to pay the bills.

What is the best way to get a red team job?

It is uncommon for people to start directly into red team jobs. The best way is to have or gain a skill such as internetworking, system administration, or software engineering and start out in a blue team role. Getting into a blue team

role will allow you gain cybersecurity experience and network with people in your dream role.

You can network internally and externally from your organization at local events and regional cybersecurity conferences. There are a couple of certifications tailored to red teaming that can get you noticed by red teams looking to add some human resources.

How can someone gain red team skills without getting in trouble with the law?

I recommend downloading virtual machines and web applications that have vulnerabilities on them when trying to learn at home. There are plenty out there; just be careful and don't put them on the internet because they will be compromised in short order.

If you don't have permission from the system owners to test or run tools, you are probably violating some law. If you are trying to get into red teaming, try to exploit only the systems that you own or systems that you have explicit written permission to exploit.

Why can't we agree on what a red team is?

I think it's human nature to want to differentiate from each other, especially in a competitive environment like the cybersecurity community. What I have learned is that there are only so many ways to solve problems. Many times we end up with the same solutions to the same problems we see. We end up having different names for the same thing. The old saying "There are no new ideas under the sun" is proven right every time I talk to people trying to solve the same issues.

What is one thing the rest of information security doesn't understand about being on a red team? What is the most toxic falsehood you have heard related to red, blue, or purple teams?

There is a natural conflict between the red team and the blue team caused by a mixture of bad experiences and misunderstandings. I think the toxic bit sometimes comes from people making mistakes like taking down servers or leaving malware on endpoints. The problem is that everyone hears red team horror stories, and there isn't a lot of data that backs anything up.

When should you introduce a formal red team into an organization's security program?

I believe that everyone in information technology and software engineering should know how to build, secure, and hack anything they are in charge of. My crazy vision is everyone always threat modeling and red teaming everything they do. You don't need to have red team as your title to utilize red team skills. I always say, "Hack more. Worry less."

How do you explain the value of red teaming to a reluctant or nontechnical client or organization?

I believe the best way to do this is to explain that even though the red team has an adversarial role, internal and external red team goals are aligned in the sense that we all want to protect sensitive data and critical systems. To keep the trust over time, red teams should always avoid showing up blue teams and internal stakeholders. You can only do this by working closely as a team. It takes only one bad experience to potentially ruin these relationships.

What is the least bang-for-your-buck security control that you see implemented?

Antivirus.

Have you ever recommended not doing a red team engagement?

I certainly have. I recommend that the organization start with vulnerability management and getting policy and governance into play. I see too many organizations out there getting “penetration tested” for compliance. I put those words in quotes because organizations are typically getting a limited-scope vulnerability scan.

What's the most important or easiest-to-implement control that can prevent you from compromising a system or network?

I'm going to go with restricting administrative privileges for end users. I've seen first hand how this drastically reduces infections on a network. This simple control applies to organizations of any size. Restricting privileges is easy to implement and scale.

Why do you feel it is critical to stay within the rules of engagement?

The only difference between a good person and a bad person is that the good person follows the rules. Violating the rules of engagement breaks the trust between teams. If you violate the rules of engagement, you may be breaking the law as well.

If you were ever busted on a penetration test or other engagement, how did you handle it?

One of the most embarrassing things I ever did related to red teaming is owning a USB thumb drive with a volume name of Marcus Carey. I ended up using the thumb drive in a server, and the forensics software detected the device that had my name on it.

I'll never make that mistake again. I'm sharing this story so it doesn't happen to you. Sharing is caring!

What is the biggest ethical quandary you experienced while on an assigned objective?

The biggest ethical quandary is being intentionally deceptive in spear phishing and social engineering. This is primarily because you could cause actual harm to people and their livelihoods on the other side of the phish.

One of my mentors would always ask for a few executives to be in scope in every engagement so management couldn't blame it on their staff. He wasn't satisfied until an executive was compromised. Sometimes he'd conceal the identity of the person whom he compromised so they wouldn't get in trouble.

How does the red team work together to get the job done?

If you are working with a team, communication is the most important element. Split up work and ensure you document everything that you do on an engagement. Trust is important as well, because I've seen situations where team members lose faith in their teammates.

I recommend using collaborative tools so everyone can see what their teammates are doing. Transparency always wins. One more thing, don't be afraid to ask for help; that's what teammates are for. If your teammate is an expert at a certain thing, simply ask for help.

What is your approach to debriefing and supporting blue teams after an operation is completed?

Professionalism is the key. Since we are all human, feelings can come into play when debriefing to internal and external blue teams. Always let them know you are on the same team as far as the big mission goes. If you do it right, they will have a detailed plan for how to correct any issues you discovered.

The hard part is when you help someone and then come back in the future and find that the same issues exist. Don't get mad. Try not to get burnt out. Stay professional and try to help. You can lead a horse to water, but you can't make it drink.

If you were to switch to blue team, what would be your first step to better defend against attacks?

I'm blue team for life, but I occasionally red team. The first step to being able to defend against attacks is putting policy in place and following it. I repeat, follow it.

People don't implement policies because it feels cumbersome. Security policy should be looked at like a map. You may not be where the policy says you are, but if you don't have a map, you'll never reach your destination.

What is some practical advice on writing a good report?

My advice is to not reinvent the wheel—there are plenty of resources out there to describe vulnerabilities, exploitation, and risk scoring. Feel free to grab content from NIST, CVSS, or MITRE ATT&CK and cite them as references. Citing them as references actually boosts the credibility of your findings and report.

Use something like CVSS to help score the vulnerabilities that you find. MITRE ATT&CK is great for discussing exploitation techniques and suggested remediations. If you use those resources, the report will be easier to write for you and easier for the consumer to trust.

How do you ensure your program results are valuable to people who need a full narrative and context?

I think it's important to use something that tells both sides of the story. I like things like the MITRE ATT&CK framework and the NIST Cybersecurity Framework because they both can be used to measure your actual capabilities and skill sets. It's possible to be effective at cybersecurity without mastering all the skill sets. Pick three things and be the best at them.

The book *From Good to Great* talks about how great businesses understand what they are good at. We can apply the same thing to cybersecurity.

How do you recommend security improvements other than pointing out where it's insufficient?

I always try to find some areas where organizations are doing some things right. So, low-hanging fruits for positive reinforcement are two-factor/two-step authentication, password length, and automatic updates.

Another way to help out as a red teamer is to understand ways to fix issues, whether on a system, on a network, or in code, that build camaraderie. I've sat side by side with Unix administrators helping them issue commands to harden systems. This is especially important if you are doing internal corporate red teams. At the end of the day, you are on the same mission.

What nontechnical skills or attitudes do you look for when recruiting and interviewing red team members?

Empathy is a great skill to have when you are delivering bad news. As a red teamer, you are going to have to give some bad news every once in a while. Put yourself in the other person's shoes and don't be a jerk.

What differentiates good red teamers from the pack as far as approaching a problem differently?

I think good red teamers study and know how things work. I mentioned empathy before. A good red teamer can put themselves in the system administrator, network engineer, or software developer mind-set and solve the problems they are facing. A good red teamer is always hungry to improve their skills and help others do so as well. ■



“There’s no ‘right way’ to become a red team member.”

Twitter: @operant

David Bell

Dave is currently the director of the red team for General Electric (GE), where he leads engagements against strategic assets in many industries across the globe. Prior to joining GE, Dave spent 10 years with the U.S. Navy red team, where he planned, led, and executed engagements against all branches of the U.S. military, many government agencies, and even coalition partners. Dave is also a veteran of the U.S. Navy, where he spent 10 years in the intelligence and special programs communities.

2

How did you get your start on a red team?

I got my start in 2006 with the U.S. Navy red team as a contractor. I had just spent about six months working nights as an IDS analyst with another contracting company, and prior to that I was on active duty in the Navy, mostly in signals intelligence. I spent a lot of time leading up to my separation from the Navy studying for certifications and hacking on home-built networks. That was enough to get me in the door, where the real learning began! I spent 10 years with that team, converted to a government civilian, and was the deputy director by the time I left. I’m now the director of the red team at GE.

What is the best way to get a red team job?

This is a question I am asked quite often, and I still struggle to answer it. There’s no “right way” to become a red team member. I worked with one really smart guy who at one point drove bulldozers. Having said that, demonstrating the ability to think like an attacker is critical and can’t be taught. We can teach technical skills, but mind-set seems to be innate. If someone has the right

mind-set, generally my advice is to pursue applicable training and certifications and get involved in capture-the-flag (CTF) events.

Like college degrees, the certifications tell me that the candidate is committed and will follow through, and the CTF events give me an idea how they will perform as part a team. I also suggest starting with other InfoSec jobs, such as pentesting or incident handling.

How can someone gain red team skills without getting in trouble with the law?

This really shouldn't be an issue anymore. There is a lot of training available, both online and in-person. Cloud platforms provide cost-effective learning environments, too; we no longer need to buy old gear from eBay or Craigslist to build a home lab.

Why can't we agree on what a red team is?

Coming from the U.S. military red team community, I have a pretty strong opinion on the misuse of this and other terms with military roots. It's tempting to blame industry marketing for this, but it really is a community problem. Penetration testing is a distinct and separate discipline from red teaming, and furthermore, there is a significant difference between internal red teams and consultant red teams. These differences can get quite confusing to customers who just want the best engagement they can get with the budget they have, and less principled teams might take advantage of this.

What is one thing the rest of information security doesn't understand about being on a red team? What is the most toxic falsehood you have heard related to red, blue, or purple teams?

Red team operations can be painfully boring. It's mind-numbing, detailed, analytical work, punctuated by moments of sheer elation and adrenaline. Most people only see the highlights in the debriefings or have misconceptions from Hollywood movies.

When should you introduce a formal red team into an organization's security program?

I often tell people that they don't need a red team engagement until they *think* they don't need a red team engagement. As soon as the organization feels like they understand all of the threats and have a good handle on things, it's time for a good red team to challenge those assumptions. And that first report won't be pretty.

How do you explain the value of red teaming to a reluctant or nontechnical client or organization?

Learning the business! I can't stress this enough. The red team has to understand what they are attacking in the context of the business they are supporting. Showing this understanding will go a long way toward establishing trust and true partnership with the customer.

What is the *least* bang-for-your-buck security control that you see implemented?

Vulnerability scanning. While this is an important security function, I rarely see it done correctly, especially at scale. If an organization is too large to keep an accurate asset inventory, how can they possibly expect to be able to scan all the things?

Have you ever recommended not doing a red team engagement?

Yes, quite often. I've found that while many customers are asking for a red team engagement, they're often really (unknowingly) looking for a web app test or

another form of limited-scope penetration test. In these cases, I will facilitate an introduction to another team that can better meet their needs. Some may see this as “losing business,” but I see it as building trust.

What’s the most important or easiest-to-implement control that can prevent you from compromising a system or network?

Endpoints rarely need to be able to communicate with each other across the network. Blocking or monitoring this type of traffic should go a long way toward limiting an attacker’s lateral movement. Keep in mind that the attacker is after data that will reside in a database, and so on. Lateral movement is used to locate and acquire the permissions needed to gain access to this data. Limit that movement as much as possible, and force the attackers to make mistakes.

Why do you feel it is critical to stay within the rules of engagement?

Rules of engagement (ROE) are used to define how the engagement should be conducted, the scope of the engagement, who should be contacted in case of emergency, and any other items of importance. The ROE is the primary safety net for both the red team and the customer, so if the red team were to deviate from those rules, systems could be damaged, or physically unsafe conditions could be created. Accidents can and do happen, however, so good ROE will define reporting processes for those incidents, and the red team will be completely honest about what happened.

If you were ever busted on a penetration test or other engagement, how did you handle it?

I’ve never done a penetration test, but I have been part of many red team engagements, including network exploitation, wireless, and even physical assessments overseas. One of my favorite stories is when my teammate and I got busted trying to convince some military personnel to let us plug in a USB thumb drive. A higher-ranking officer overheard the conversation from the next room and immediately rushed in to confront us. He was shaking with anger and informed us, “The red team did this to me last year, and you’re not going to do it again!”

I had no idea what he was talking about, but knew I had two choices: I could either back down and admit I was caught, or I could maintain character and react the same way anyone else in that position would have. I chose the latter and started shouting back that I didn’t appreciate accusations while I was just trying to do my job. He didn’t buy it for a second, but I wasn’t going to give him the satisfaction. He took us to his security officer, who informed him that our (actually fake) ID cards looked normal to him. While the first officer left the room to retrieve the encryption key for his phone (so he could call “my boss”), I explained to the security officer that we had an authorization letter in the car, and we would just grab that and be right back.

Once we got in the car, we still had to get off the base, which was nerve-racking as well! That evening I discovered that there was a “be on (the) lookout” alert (BOLO) for me issued by the local host-nation police (no doubt the work of the angry senior officer), so I left the country shortly after. I didn’t fully relax until I cleared customs in the United States.

What is the biggest ethical quandary you experienced while on an assigned objective?

Being asked to “target” specific individuals is always a little creepy. I prefer not to and will always argue against it. I have no problem targeting specific roles or positions within an organization, however, as long as there is a solid threat model justifying it. One example is that I’ve been asked to look at the social

media profiles of executives and their families. Careful controls need to be in place, and permission given, before I will entertain tasks like this.

How does the red team work together to get the job done?

The ability to function as a cohesive team is often what separates highly effective teams from those that are not. While every team member is important, skilled, and talented, no team member is so highly skilled that they can complete an engagement without the help of their teammates. Similarly, no red team operator should ever work on an engagement alone. Either physically or virtually, another operator should be working on the same engagement so they can function as a safety/sanity check for each other.

Detailed documentation is of the utmost importance during red team engagements. The customer is paying for the information contained in the report, which is derived from detailed, disciplined logging done during the actual engagement.

What is your approach to debriefing and supporting blue teams after an operation is completed?

Debriefs should always be tailored to the audience. Defenders should get an in-depth technical report that walks them through the attack path from start to finish. Ample time for questions should be scheduled, and the red team should be prepared for any follow-up reports for key people who weren't able to attend for some reason. I also encourage the teams to be available for mini-retests or other forms of support to enable defenders to learn from the engagement.

This is a partnership, and the report should reflect that—you should state facts without ego and recognize that some people are going to be embarrassed or defensive. Be sure to also give credit where credit is due.

If you were to switch to the blue team, what would be your first step to better defend against attacks?

Prevention is preferred, but detection is a must. My first step would be to understand what data sources were available and make sure they were accessible to defenders. Many defenders have complained of data overload, but almost every engagement I've ever been part of had shown some kind of blind spot. The more data available to automation and manual queries, the more likely an attack will be detected.

What is some practical advice on writing a good report?

Stick to the facts, and paint the picture of the attack path. Don't use jargon, and provide references to CVEs or technical guides wherever possible. The report is the product you are providing; it is what the customer is paying for. Nothing else matters, so get this right every time. If there are follow-up questions, answer them promptly and accurately and make note of them for your next report.

How do you ensure your program results are valuable to people who need a full narrative and context?

This will vary with each organization, but a good way to start is to identify who the red team's true customers are. Customers are different than stakeholders, and this differentiation becomes important when trying to prioritize engagements and reports.

Once the true customers and stakeholders are identified, red team leadership should begin to tailor their communications to those individuals. Reports should be at the correct level of detail and clearly answer the inevitable "so what?" question before it is even asked. This requires learning the business and understanding how the technology your team has just assessed fits into

those processes (and therefore the impact of your team's actions on the business as a whole). The business is the ultimate customer, and the business does not exist solely to run a CIRT (or a red team).

How do you recommend security improvements other than pointing out where it's insufficient?

Red teams are often asked for recommendations for security improvements, but frustratingly, the answer is almost always "it depends." Red teams provide a snapshot-in-time look at an environment. Red teams likely have no idea *why* the environment looks the way it does, but almost certainly there were decisions made at some point, for some business reason, to design and build the environment in that particular way. One way to take this into account is for the red team to sit down with the teams responsible for implementing fixes and walk through the attack path from start to finish.

This helps the network owners get a peek into the mind of the attacker, and it helps the red team understand what challenges the network owners face. Then, potential mitigations can be brainstormed and table-topped at that moment, resulting in quality recommendations that can actually be implemented. The red team can even come back at a later date and retest the environment to see whether the recommended fixes are performing as intended.

What nontechnical skills or attitudes do you look for when recruiting and interviewing red team members?

When I am talking to candidates, I am looking for positive attitudes and strong internal drive/motivation. Red teamers will often find themselves neck-deep in mind-numbing analysis, the results of which could determine the success of the engagement.

Therefore, it is important that candidates are able to motivate themselves to keep going, not lose sight of the objective, and not complain that they're "not doing cool stuff." Red team work is usually pretty boring, minus the moments of sheer adrenaline when that shell finally comes back, so candidates need to give the impression that they have the patience and determination to accomplish the mission.

What differentiates good red teamers from the pack as far as approaching a problem differently?

Good red teamers are able to think, plan, and act like an attacker. This ability is often referred to as the *attacker mind-set*, but it's more of a lifestyle than something that can just be turned on or off as needed. For example, once a good red teamer has been trained and has conducted physical engagements, that red teamer will habitually and unconsciously "case" every building they enter. They will automatically make note of the position and angle of cameras, security personnel, type and condition of locks on doors and windows, and so on, all without thinking about it. The same is true for red teamers on the keyboard: they will develop an innate ability to "feel" vulnerabilities and intuitively understand not only how to exploit them but whether they *should* exploit them in furtherance of their ultimate objectives.

This quality is difficult to identify in candidates and even harder to express in words. However, I have seen good results from having candidates demonstrate their talents in skills challenges during the last stages of the interview process. How a candidate approaches problems in a high-pressure virtual environment tells us quite a bit about whether the attacker mind-set is fully present, needs developing, or simply doesn't exist within a candidate. Not everyone can think this way, and not everyone is cut out to be on a red team, and that's okay. I've seen very smart people struggle with this aspect but then go on to build successful careers in other aspects of cybersecurity. ■



“As you can imagine, the best way to get a red team job is to first understand what it is that you want to do and then build a technical skill set and foundation to align with what that type of role would entail.”

Twitter: @ProfBrager

Paul Brager

3

Regarded as a thought leader and expert in the cybersecurity community for more than 25 years, Paul has deep expertise evaluating, securing, and defending critical infrastructure and manufacturing assets (ICS, IoT, and IIoT). An avid speaker and researcher, Paul seeks to move the conversation forward surrounding ICS cyber and managing the threat surface.

He has provided commentary on several security-related podcasts, publications, and webinars that provided guidance and insight into strategies for critical infrastructure and manufacturing cyber defense. Paul has a passion for mentoring and guiding people of color who are aspiring to contribute to the advancement of the industry and promoting diversity within the cyber community.

How did you get your start on a red team?

My red team beginnings (much like most experiences in this space) came about from necessity. Company leadership fired a “legacy” employee who was using a Windows 95 desktop with local accounts (yes, Windows 95). At the time, it wasn’t uncommon for workstations to not be part of a domain (Windows domains weren’t terribly common in the mid-’90s), but there also weren’t many methods of getting into a workstation if the password was lost. Novell was still king of the network operating systems, so you get the picture. Recovering a machine typically means re-installing over the top of it and hoping that you didn’t step on any of the critical documents/areas or getting into it with one of many “magic boot disks” that had started to appear at the time.

These were generally Slackware-based, but you needed some “skills” to be able to get them to work without destroying the master boot record (MBR) on the target. “Hacking” those disks with predictable results became more of an

art than a science, as you needed not only some Linux/BSD knowledge but also knowledge of how partitions worked within Windows. After spending countless hours building (and rebuilding) a Windows 95 test machine to get the parameters correct, I was able to successfully gain access to the Windows 95 workstation and recover valuable source code that would have cost the company months in development.

What is the best way to get a red team job?

Well, it depends—red team job doing what? Pure penetration testing? Survivability testing? Penetration testing against certain classes of assets, in other words, ICS? As you can imagine, the best way to get a red team job is to first understand what it is that you want to do and then build a technical skill set and foundation to align with what that type of role would entail. Experience is generally key here but not always—sometimes raw knowledge and demonstrated know-how are enough. Much of how you are received as a legitimate red teamer is left to the devices of those interviewing, but those who can truly recognize talent may show interest. Networking, either in person or through social media (or both), remains one of the strongest ways to get insight into available red team roles, but you may also luck out and talk to someone in a position to make a hiring decision.

How can someone gain red team skills without getting in trouble with the law?

Today, gaining red team skills without getting into legal trouble is easy. Many of the tools that one would need to practice are open source and easily downloaded; the same is true about access to many of the operating systems that would be potential targets. The world of virtualization has opened the door to the creation of virtual labs that can be destroyed and rebuilt with no impact to anyone—other than you, of course. Additionally, there are numerous hackable platforms available to test various skills and abilities (such as Hack The Box) to further hone red teaming skills. The more specialized type of practice—against ICS assets, for example—is a bit trickier, although some PLCs (the primary targets in an ICS) can be purchased on eBay. Likewise, IoT devices (such as Raspberry Pis) can be purchased inexpensively to develop skills against those.

Why can't we agree on what a red team is?

As with many things in cybersecurity, there is always an implied “it depends” when discussing what constitutes red teaming. Some believe that red teaming is just hacking; others believe that red teaming is far more robust and systematic than that. I believe that ultimately it depends on the perspective of the audience. For those in a purely corporate setting, red teaming gives a more elegant name to penetration testing with a nonmalicious purpose. It infers a sense of structure and methodology that leverages offensive security capabilities to uncover exploitable vulnerabilities. Among the hacker community, however, there may be a much looser definition being used.

What is one thing the rest of information security doesn't understand about being on a red team? What is the most toxic falsehood you have heard related to red, blue, or purple teams?

Being on a red team does not automatically make a person nefarious or malicious. Rather, what excites them within the realm of cybersecurity tends to be more the offensive capabilities. Researching and discovering exploitable vulnerabilities is both tedious and painstaking, and to be able to do so *and* articulate findings in a consumable manner is more an art than a science. While

their pedigree may be hacker-made, it does not define them but legitimizes their necessity within the cybersecurity ecosystem.

Perhaps the most toxic falsehood to date that I have heard is that cybersecurity professionals completely fit within one of three buckets: red team, blue team, and purple team. This gives the perception that cybersecurity professionals are single-threaded, which simply isn't true at all. While each professional may have more of an affinity to one or the other depending on how they have matured within cybersecurity, it is functionally impossible to not consider the other buckets. Red teamers must understand how their penetration attempts could be thwarted or detected and come up with countermeasures to lessen the likelihood of that happening. Blue teamers must understand at some level the TTPs that adversaries are launching to better develop countermeasures to repel them. Most cybersecurity professionals are a shade of purple, being more red or blue depending on affinity and maturity in the field.

When should you introduce a formal red team into an organization's security program?

A formal red team can be introduced into a security program at any point. The value and benefit of doing so largely depends on what is to be gained from the red team exercises. If the intent is to understand the threat surface and to what degree a program (or a part of the program) is vulnerable, then it is reasonable to engage red team services early in the program's develop phase as a tool to better frame overall risks. Similarly, formal red team engagement can be part of the overall security strategy and lifecycle to reassess the robustness of controls and the organization's ability to detect and respond.

How do you explain the value of red teaming to a reluctant or nontechnical client or organization?

Lobbying for red teaming within one's organization can be challenging, particularly if the organization's security program has not matured beyond vulnerability assessment and/or vulnerability management. Additionally, if the organization has not sufficiently invested in or implemented controls or resources, red teaming may uncover vulnerabilities that have not been budgeted for and which there are insufficient resources to address, which exacerbates the problem. My approach has always been to frame the notion of red teaming as a function of risk management/mitigation. Red teaming allows for an organization to find potentially damaging or risky holes in their security posture before bad actors exploit them, minimizing the potential impact to company reputation, customers, and shareholders. Taking this approach makes the question of whether to use red teaming a business decision, as opposed to a technical one.

What is the *least* bang-for-your-buck security control that you see implemented?

With the myriad of security products, services, and capabilities that are on the market, they all should be supporting two principal edicts: detect and respond. However, many security organizations are not staffed appropriately to consume and act on all the data that is available to them from these tools. Standalone threat intelligence tools, in my opinion, offer the least bang for the buck because they still require contextual correlation to the environment, which implicitly requires human cycles. Even with automation and orchestration between firewalls, SIEM, and IDS/IPS, correctly consuming threat intelligence requires resources—and burns cycles that may be better utilized elsewhere. The robustness of many of the more effective controls (firewalls, IDS/IPS, EPP) will generally give you the threat context that is necessary to detect and respond, without the overhead of another tool.

Have you ever recommended not doing a red team engagement?

Typically, a customer or an organization can always benefit from some form of “red team” activity, even if it is just a light penetration test. In my consulting life, we generally would recommend against a full-blown red team exercise if there was significant immaturity evident within the organization’s security program or if the rules of engagement could not be settled upon to safely conduct the red team exercise. What has been recommended in the past is a more phased approach, going after a limited scope of targets and then gradually expanding as the organization’s security maturity increases.

What’s the most important or easiest-to-implement control that can prevent you from compromising a system or network?

Security awareness training can be one of the easiest and most important controls that bolsters the overall security posture of an organization. User behavior can be the difference between a managed threat landscape and an unruly one, and in many instances, the end user will see incidents before security. Educate and empower users to practice good cyber hygiene. Beyond that, certain security controls that are cloud-based can be leveraged to offset the capital costs of infrastructure, if that is a barrier. This is particularly true in small to medium-sized businesses with limited staff and/or budgets.

Why do you feel it is critical to stay within the rules of engagement?

Rules of engagement are established as the outer markers for any red team/pen testing exercise. They basically provide the top cover for activities that may cause harm or an outage, even if unintentional. Additionally, the rules of engagement can be your “get-out-of-jail-free” card should something truly go sideways, as they generally include a hold harmless clause. Deviating from the stated rules of engagement without expressed written consent of the client could open you up to legal liability issues and be devastating to your career.

If you were ever busted on a penetration test or other engagement, how did you handle it?

I had an instance where a physical penetration test was being conducted for a client, and the sponsor had neglected to notify site security about my presence. After gaining access to the facility through a propped-open door in the back (repair personnel didn’t want to keep badging in), I was walking through the facility with a hard hat that I had “borrowed” from a table, and I was apprehended by site security and the local police. To make matters worse, my contact was unavailable when they called to confirm that I was authorized to conduct the penetration test. After two intense hours of calling everyone that I could to get this cleared up and the threat of charges being filed, the contact finally called back and I was released without being arrested.

What is the biggest ethical quandary you experienced while on an assigned objective?

Without question, the biggest ethical quandary I’ve experienced is stumbling upon an account cache, financial records, or PII in a place where they shouldn’t be and being told by the sponsor not to disclose the details to the impacted individuals until the penetration testing exercise was complete, which may be over several days. For me, there are certain discoveries that take priority and need to be acted upon immediately, particularly when it is PII or financial information. In this case, the sponsor was attempting to prove a point to another member of management and had virtually no regard for what had been discovered.

How does the red team work together to get the job done?

Red teaming, as the name implies, generally involves more than one person. The coordination that is needed to engage in a penetration test against multiple targets requires clear accountability as to what is expected of each team member. Additionally, there are generally members of the team who are better at certain tasks than others—those more suited to speaking with the customer do so, those more technical stick to those roles, and so on. It is always useful to have a team of red teamers comfortable speaking with customers, as each of them (particularly in large engagements) may have to report at different times to different audiences.

What is your approach to debriefing and supporting blue teams after an operation is completed?

When I was consulting, there would be two report-outs. One would be for management and reported on the high-level activities that were conducted, what was found, and the risk concerns that had arisen from those findings. Any extraordinary findings would be enumerated within that conversation so that if any legal or other actions needed to get underway, the accountable parties could get started. The second report was the technical deep-dive; it was generally divided into finding areas, and individual small sessions were conducted with blue team designees to confirm what was in the report and walk through any questions. It was also during these sessions that follow-on remediation efforts and next steps would be discussed.

If you were to switch to the blue team, what would be your first step to better defend against attacks?

Having lived on both sides of the fence, one of the things I am always amazed about is the lack of contextual visibility—not just logs and so on, but actual visibility with context into the associated assets. Additionally, there still seems to be considerable challenge in identifying assets within the ecosystem. The introduction of IoT (IIoT in the industrial world) has exacerbated this problem. Those two areas need to be addressed from a defense-in-depth approach because you simply cannot defend what you cannot see and identify. Effective cybersecurity defense is deployed in layers so that even if attackers get past one layer of defenses, it is increasingly difficult for them to get past subsequent layers. Lastly, I would spend more time and energy on security awareness training and arming the end user with the information needed to change behavior.

What is some practical advice on writing a good report?

When writing a testing report, it is important to understand what the objective of the customer is and write the report to align with those objectives. At the end of the day, any remediation efforts are going to need to be funded, and the more the testing report can help build that case, the more likely the client is to reach back out to your entity (or you) for follow-up work. Consider what the customer would need to show management to compel them to act. Get feedback from the customer during the drafting process and incorporate it; certainly the style and tone of the report can be critical to the efforts of the security function within that organization. Seek to highlight areas where the security function performed well, followed by findings characterized by risks. Also keep in mind that the content will have to be defended, so make the language succinct and as unambiguous as possible.

How do you ensure your program results are valuable to people who need a full narrative and context?

In my experience, how value is added to the red team program varies from organization to organization, but principally it should align with the overall security program and the risk posture of the organization. The program should strive to enumerate material and exploitable vulnerabilities within a given ecosystem, understanding that all findings may not be outside of the organization's risk tolerance, whereas some may be nonnegotiable as a risk that absolutely has to be mitigated. In either case, the ability to link the red team program to some repeatable metric, such as the number of materials and exploitable vulnerabilities found, the number of successful versus unsuccessful attacks, or the number of false positives, can go a long way in legitimizing the value of the effort. Your skill set really doesn't matter if the work you are doing doesn't align with something of value to the business. Senior management isn't interested in a report showcasing how skillful and smart you are—what they *are* interested in is their overall risk exposure given what you have discovered, so frame your activities in that light.

How do you recommend security improvements other than pointing out where it's insufficient?

In any red team exercise, it is important to highlight those areas where the customer/organization did things well. For instance, if the organization has a robust patching program and it led to a smaller attack surface for the red team, be certain to acknowledge that. Remember, part of the job of a red team is to legitimize not only its skill capability but its intrinsic value as part of the security program. If the red team cannot contribute to the success of the security program to get the funding it needs, then its value is severely diminished. Conversations with blue team members should be as informative as possible, and if both teams come from the same company, it may be useful for the red team members to assist the blue team in identifying countermeasures. Be a source of expertise that is not just for hacking into systems but also for securing them—help the blue team think like hackers (assuming they aren't already).

What nontechnical skills or attitudes do you look for when recruiting and interviewing red team members?

The most important nontechnical skill any security professional can have is strong communication skills. When recruiting for red team members, there must be an air of trustworthiness and integrity within the candidate. Red teamers will have access to very sensitive knowledge about infrastructures, security controls, vulnerabilities, and so on, and that information will need to be held in the utmost of confidence. The ability to be not only technically astute but also able to explain those technical concepts to the layperson is invaluable in a red team asset.

What differentiates good red teamers from the pack as far as approaching a problem differently?

Good red teamers are not only technical hackers but also have an innate understanding of what value their activities represent to their organizations (as an employee or consultant). Good red teamers are thorough and detail-oriented and comfortable with their own skill. Good red teamers are always looking to hone their abilities and figure out ways to exploit without detection. Problem-solving can be highly methodical, or it can be serial. Regardless of the approach, a good red teamer applies the proper approach when necessary and adjusts when that approach runs into a dead end. ■